

Guía Consolidada de Defensa Técnica

Estrategia de Ciberseguridad, Gobernanza, Arquitectura y Matriz de Responsabilidades (SGSI)

El presente documento recopila de manera estructurada todos los conceptos clave, análisis críticos de control interno y el banco de preguntas y respuestas desarrollados para la defensa de la propuesta tecnológica y organizativa del Sistema de Gestión de Seguridad de la Información (SGSI). Está diseñado para servir como herramienta avanzada de preparación ante comités evaluadores, auditores y la alta dirección.

Bloque 1: Estructura Organizacional y Gobernanza del SGSI

Este bloque aborda el marco de gobernanza institucional, estableciendo las líneas de autoridad, toma de decisiones y la integración transversal de la seguridad dentro de la organización.

1. Función Transversal:

Establece que la seguridad de la información no pertenece a un silo o departamento técnico exclusivo (como TI), sino que permea e impacta a la totalidad de las áreas de la organización (Operaciones, Administración, Recursos Humanos y Dirección).

2. Sistema de Gestión de Seguridad de la Información (SGSI):

El marco holístico compuesto por políticas, procesos, tecnologías y personas diseñado para proteger la confidencialidad, integridad y disponibilidad de los activos de información institucionales.

3. Trinomio de Gobernanza Operativa:

La síntesis del flujo jerárquico del modelo propuesto: la Dirección General **decide y responde**, el Comité de Seguridad **coordina**, y las unidades de Tecnología y Seguridad **ejecutan**.

Banco de Preguntas y Respuestas de Control

P1: ¿Por qué se afirma que la seguridad de la información es una "función transversal" si existen un Departamento de Tecnología y una Unidad de Seguridad dedicados?

R: Porque las políticas y los riesgos de seguridad impactan transversalmente a toda la organización (desde Operaciones Digitales hasta la Dirección Administrativa). Mientras que las áreas de Tecnología y Seguridad ejecutan las salvaguardas y medidas técnicas operativas cotidianas, el cumplimiento normativo, la gestión de riesgos de negocio y la cultura de seguridad involucran obligatoriamente a cada colaborador y proceso operativo de la empresa.

P2: ¿Quién es el máximo responsable del SGSI en la organización y cuál es su función exacta?

R: La **Dirección General** ostenta la responsabilidad político-institucional y legal última sobre el SGSI. Su función es estrictamente estratégica: es la figura que rinde cuentas ante entes reguladores, aprueba los presupuestos e inversiones financieras necesarias y otorga el respaldo institucional definitivo para la adopción obligatoria de las políticas de seguridad.

P3: ¿Cuál es la diferencia sustancial entre las funciones de la Dirección General y las del Comité de Seguridad de la Información?

R: La Dirección General posee la última palabra y la rendición de cuentas institucional (responde civil o penalmente por el sistema). En contraste, el Comité de Seguridad de la Información actúa como un órgano táctico y colegiado de gobernanza. Su rol es coordinar las distintas áreas, evaluar de forma detallada los riesgos mitigados, redactar y proponer políticas específicas, y estructurar los planes de continuidad del negocio (BCP).

P4: ¿Cuál es la función real e impacto de la Dirección Administrativa dentro de este esquema de seguridad?

R: Su función principal es gestionar e implementar los **controles de seguridad no técnicos**, enfocándose en tres áreas críticas de la seguridad operativa:

- **Seguridad de los Recursos Humanos:** Asegurar la firma de acuerdos de confidencialidad (NDAs), realizar la verificación de antecedentes previa a la contratación y coordinar el proceso seguro de baja o salida de colaboradores (revocación inmediata de accesos físicos y devolución de activos tecnológicos).
- **Seguridad Física y Ambiental:** Diseñar y operar los controles de acceso a las instalaciones físicas, monitoreo por CCTV, resguardo perimetral de oficinas y protección de las salas de servidores o cableado.
- **Gestión de Proveedores y Contratos:** Garantizar que los terceros, contratistas o consultores externos firmen e implementen cláusulas estrictas de protección de datos alineadas con el SGSI.

P5: ¿Por qué la Dirección Administrativa se sitúa al mismo nivel jerárquico que Tecnología y Seguridad bajo el Comité?

R: Porque estadísticamente más del 80% de los incidentes graves de seguridad se originan debido al factor humano, ingeniería social o fallas de acceso físico, y no por vulnerabilidades informáticas directas. Posicionar a la Dirección Administrativa en este nivel jerárquico garantiza que las directrices del SGSI posean la misma fuerza coercitiva y procedimental en el entorno contractual, físico y de personal que en los entornos puramente digitales.

P6: ¿Cómo se organiza el Departamento de Tecnología para dar soporte y ejecución operativa a esta estructura?

R: Se divide en cuatro frentes especializados para garantizar una cobertura técnica integral del ciclo de vida de los servicios:

- *Desarrollo y Aplicaciones:* Encargado de la seguridad en el ciclo de vida del software (DevSecOps) y codificación segura.
- *Infraestructura y Redes:* Responsable del blindaje de servidores, enlaces de comunicaciones y topologías de red.
- *Soporte Técnico y Mantenimiento:* Velando por la higiene y respuesta a incidentes directos en los terminales de los usuarios.
- *Gestión Documental y Datos:* Enfocado en el almacenamiento seguro, políticas de retención, cifrado en reposo e integridad informática de las bases de datos.

CONSEJO DE DEFENSA ESTRATÉGICA

Si un evaluador cuestiona la ausencia explícita de sub-áreas como "Recursos Humanos" o "Compras" en el organigrama de gobernanza, responda con contundencia: *"Dichas áreas están contempladas operativamente. En este modelo de gobernanza corporativa, tanto Recursos Humanos como Compras y Servicios Generales operan bajo la sombrilla y coordinación de la Dirección Administrativa, la cual centraliza y reporta el cumplimiento de sus respectivos controles no técnicos directamente ante el Comité de Seguridad"*.

Bloque 2: Arquitectura Tecnológica Propuesta

Análisis del diseño técnico de infraestructura basado en principios de aislamiento, capas concéntricas de seguridad y resiliencia ante ataques persistentes.

1. Defensa en Profundidad (Defense in Depth):

Estrategia de diseño que asume que cualquier control individual puede fallar. En su lugar, se implementan múltiples capas concéntricas e independientes de protección para ralentizar o detener la progresión de una amenaza.

2. Segmentación de Red y Control Lateral:

Aislamiento estricto de los entornos en zonas independientes (compartimentos estancos). Su objetivo primordial es bloquear la **movilidad lateral** de un atacante, evitando que la vulneración de una capa exponga automáticamente las demás.

3. Reducción del Radio de Impacto (Blast Radius):

Principio arquitectónico que busca limitar el daño potencial de un incidente informático de forma que quede confinado exclusivamente a la zona afectada, manteniendo la resiliencia en el resto de los entornos.

Banco de Preguntas y Respuestas de Control

P1: ¿Cuál es la diferencia operativa entre el Firewall y el WAF implementados en la Zona Perimetral (Zona 2) y por qué se requieren ambos?

R: Operan en capas diferentes del modelo OSI. El **Firewall tradicional** trabaja a nivel de red y transporte (Capas 3 y 4), inspeccionando IPs de origen/destino y filtrando puertos genéricos (como túneles VPN). Por su parte, el **WAF (Web Application Firewall)** actúa en la capa de aplicación (Capa 7), decodificando e inspeccionando el tráfico HTTP/HTTPS en tiempo real para neutralizar ataques web complejos dirigidos específicamente contra el código de la aplicación (como SQL Injection, Cross-Site Scripting o manipulación de parámetros), los cuales un firewall tradicional es incapaz de detectar. Ambos controles se complementan para blindar la frontera de la red.

P2: Si un atacante compromete con éxito el Servidor de Aplicaciones (Zona 3), ¿cómo garantiza esta arquitectura la protección inmediata de la Base de Datos Ciudadana (Zona 4)?

R: Se garantiza mediante la segmentación estricta y firewalls de aislamiento interno entre zonas. El Servidor de Aplicaciones no posee libre acceso ni visibilidad total sobre la Zona 4; la intercomunicación está limitada de forma estricta a través de un puerto de datos específico, con credenciales de base de datos restringidas bajo el principio de mínimo privilegio y únicamente para la ejecución de consultas y procedimientos parametrizados. Cualquier intento de escaneo de red o salto lateral no autorizado activa las alarmas en el "Sistema de logs y monitoreo", bloqueando la conexión de forma automatizada.

P3: ¿Por qué el "Servicio de Autenticación" se localiza físicamente en la Zona de Aplicaciones (Zona 3) y no en la Zona de Datos (Zona 4), considerando que esta última es la más protegida?

R: Por diseño de control de accesos e intermediación de red. El Servicio de Autenticación debe estar de cara al exterior para interactuar directamente con los usuarios (ciudadanos y funcionarios) y procesar sus credenciales de ingreso de forma dinámica. Posicionarlo en la Zona de Aplicaciones permite que funcione como una barrera de control lógico intermedia. Si se ubicara en la Zona de Datos, obligaría a abrir canales de comunicación directos desde la Zona de Usuarios (exterior) hacia el núcleo más profundo de almacenamiento, rompiendo el principio fundamental de aislamiento perimetral de las bases de datos.

P4: Con respecto a la resiliencia: ¿Por qué el "Sistema de Respaldos" comparte zona con la Base de Datos? Si dicha zona es comprometida, ¿no estaríamos arriesgando la continuidad?

R: Comparten la "Zona de Datos y Continuidad" a nivel de clasificación lógica de seguridad porque los respaldos requieren exactamente el mismo nivel máximo de confidencialidad e integridad legal que la base de datos en producción. Sin embargo, arquitectónicamente se implementa bajo la **regla de respaldos 3-2-1**: el almacenamiento de los backups se encuentra aislado física o lógicamente en un segmento inmutable o en una nube dedicada, utilizando políticas de "solo escritura" (Write Once, Read Many - WORM), impidiendo que un incidente de cifrado por ransomware en el entorno de producción pueda alterar o borrar las copias de seguridad de la institución.

P5: Explique el flujo seguro que realiza la información de un ciudadano desde que interactúa con su terminal móvil hasta que se consolida en la base de datos.

R: El viaje de los datos sigue un trayecto rigurosamente auditado y protegido:

1. El terminal móvil (Zona 1) inicia una petición web cifrada de extremo a extremo utilizando protocolos seguros ****TLS****.
2. La petición golpea la ****Zona Perimetral (Zona 2)****, donde el Firewall valida los parámetros de red y el WAF realiza una inspección heurística profunda para descartar código malicioso.
3. Superado el filtro, el tráfico accede al ****Portal Web y Servidor de Aplicaciones (Zona 3)****, que procesa la lógica de negocio del trámite e interroga al Servicio de Autenticación para validar la identidad digital del usuario.
4. Finalmente, la aplicación empaqueta una transacción limpia y la transmite de forma controlada a través de un canal exclusivo e interno hacia la ****Base de Datos y Repositorio de Expedientes (Zona 4)**** para su almacenamiento definitivo.

RECOMENDACIÓN PRÁCTICA PARA LA PRESENTACIÓN

Durante la exposición de este slide, utilice un apoyo visual directo (puntero o gesticulación) siguiendo estrictamente el flujo de izquierda a derecha. Enfatique verbalmente que **los controles y las restricciones de acceso se vuelven exponencialmente más severos a medida que se avanza hacia la derecha**, logrando que el evaluador comprenda visualmente cómo la Zona de Datos queda blindada tras múltiples perímetros virtuales.

Bloque 3: Inventario de Activos Tecnológicos y Criticidad

Este bloque establece los cimientos cuantitativos del análisis de riesgos bajo metodologías de gobierno de TI (ISO 27001), priorizando los recursos informáticos clave de la institución.

1. Activos de Información vs. Activos de Soporte:

Los activos de *Información* representan los datos puros y el conocimiento valioso del negocio (bases de datos, expedientes). Los activos de *Soporte* constituyen los componentes de software, hardware y servicios físicos que permiten almacenar, procesar, transmitir o defender dichos datos.

2. Criterios de Criticidad Operativa (Tríada CID):

Clasificación del impacto estratégico sobre el negocio si se vulnerara la **Confidencialidad** (exposición), **Integridad** (corrupción de datos) o **Disponibilidad** (caída del servicio) de un activo. Si la afectación de cualquiera de estas tres variables detiene la operación institucional o genera consecuencias legales graves, el activo es catalogado como ****Crítico****.

Banco de Preguntas y Respuestas de Control

P1: ¿Cuál es el sustento metodológico para clasificar al Servidor de Autenticación como "Crítico" mientras que el Servidor de Aplicaciones se mantiene como "Alta"?

R: Radica en el impacto de una brecha en la Confidencialidad versus la Disponibilidad. Si el Servidor de Aplicaciones sufre un incidente, se degrada temporalmente la continuidad operacional de los trámites públicos (Afecta Disponibilidad - Nivel Alto). No obstante, el ****Servidor de Autenticación**** administra los privilegios de acceso al entorno completo; si se ve comprometido, un atacante podría suplantar identidades legítimas, evadir auditorías y ganar control no autorizado sobre **la totalidad** de los expedientes confidenciales y bases de datos sensibles (Vulnera Confidencialidad e Integridad de forma masiva - Nivel Crítico). Es la diferencia entre perder el motor y perder el control de todas las llaves del edificio.

P2: Si las Estaciones de Trabajo Administrativas representan estadísticamente el vector de entrada prioritario de amenazas como malware y ataques de phishing, ¿por qué figuran únicamente con criticidad "Media"?

R: Porque la criticidad evalúa el valor intrínseco del activo de cara al núcleo operacional y los datos residentes en él, no la probabilidad del ataque. Gracias a la ****arquitectura tecnológica segmentada**** definida previamente, las estaciones de trabajo se encuentran confinadas en la zona de usuarios y carecen de almacenamiento persistente de datos sensibles como expedientes o registros de la base de datos ciudadana. Por ende, aunque el **riesgo latente** del canal es alto, el **impacto directo en el negocio** si un terminal se infecta es controlado y de nivel Medio, permitiendo su aislamiento rápido sin interrumpir la operación central.

P3: Herramientas esenciales de protección como el Firewall / WAF y el Sistema de Logs vigilan todo el ecosistema informático. ¿Por qué razón no están clasificados como "Críticos"?

R: Son catalogados como activos de soporte y de carácter puramente defensivo/monitoreo. Si el Firewall sufre una falla de software, la seguridad de la organización se debilita ostensiblemente y entra en un estado de alerta severo (Criticidad Alta), pero la información interna institucional no se corrompe ni se destruye automáticamente en ese instante. En cambio, si la Base de Datos Ciudadana o el Repositorio de Expedientes sufren una alteración o borrado directo, el impacto negativo de negocio, legal y reputacional sobre la institución es inmediato, catastrófico e irreversible por sí mismo.

P4: ¿Bajo qué lógica regulatoria el Sistema de Respallos obtiene una calificación tan alta ("Crítica"), equiparándose a la base de datos de producción?

R: Bajo el paradigma moderno de la resiliencia en ciberseguridad, que establece que la prevención total no existe y que los incidentes graves eventualmente van a ocurrir. El Sistema de Respallos representa la última línea de supervivencia institucional frente a un desastre o un ataque de ransomware destructivo. Si la base de datos es cifrada y el sistema de respaldos es defectuoso o inexistente, el impacto de continuidad es la muerte operativa total de la institución. Por tanto, su protección y nivel de criticidad deben ser idénticos al del activo que resguarda.

RECORDATORIO DE CONTROL INTERNO NUMÉRICO

Para garantizar precisión matemática durante la defensa, mantenga en mente el número exacto del alcance del inventario presentado en la matriz: **10 activos clave en total**, distribuidos simétricamente en **4 activos de criticidad Crítica**, **4 activos de criticidad Alta** y **2 activos de criticidad Media**. Ante preguntas de exhaustividad, confirme que el alcance se acotó estrictamente al perímetro del proyecto del SGSI aprobado.

Bloque 4: Organización Técnica y Matriz RACI

Estructura de responsabilidades operativas y mecanismos de control interno diseñados para prevenir la duplicidad de esfuerzos, asegurar la segregación de funciones y garantizar la trazabilidad de las acciones técnicas.

1. Segregación de Funciones (Segregation of Duties - SoD):

Directriz de control interno que prohíbe que una misma persona ejecute tareas operativas y, simultáneamente, valide, audite o apruebe dichas acciones. Su propósito es evitar fraudes, encubrimientos o colisiones de intereses.

2. Accountable (Aprobador Único) Único:

La regla irrompible de la ingeniería de procesos mediante matrices RACI. Mientras que la ejecución operativa (Responsable - R) puede recaer sobre múltiples actores en paralelo, la autoridad final y la obligación de responder ante incidentes (Accountable - A) debe concentrarse en una **única persona por actividad** para evitar la dilución de responsabilidades.

3. Eliminación de Zonas Grises Operativas:

Mecanismo procedimental que formaliza los roles exactos del personal de TI frente al negocio, erradicando la ambigüedad de "quién debía ejecutar qué" ante la ocurrencia de incidentes críticos de infraestructura o caídas de sistemas.

Banco de Preguntas y Respuestas de Control

P1: Al analizar la actividad "Planificar mantenimientos programados", el Jefe de TI figura bajo la etiqueta combinada de "A/R" (Aprobador y Responsable). ¿No representa esto una debilidad de control interno o un conflicto de interés operativo?

R: No, es una asignación correcta para este tipo de procesos internos de carácter estratégico-departamental. En la fase de planificación operativa interna de un área de TI, es perfectamente válido y eficiente que el líder técnico sea quien diseñe la propuesta de calendario (Responsable de la ejecución de la tarea) y que posea la facultad interna para validar la distribución de sus recursos humanos (Aprobador técnico). Sin embargo, el control interno se mantiene robusto mediante dos salvaguardas externas: la *Política de mantenimiento* global es aprobada exclusivamente por la Dirección General (Fila 1) y las ventanas de impacto operativo se deben comunicar formalmente de forma institucional (Fila 8), impidiendo que el Jefe de TI actúe de manera aislada o discrecional en perjuicio del negocio.

P2: ¿Por qué razón el Oficial de Seguridad tiene asignada una "R" (Responsable) únicamente en la actividad "Revisar logs y alertas operativas", mientras que en el resto de los procesos se limita a figurar como "C" (Consultado)? ¿No denota esto una falta de implicación directa?

R: Al contrario, responde a un diseño estricto y transparente de **Segregación de Funciones (SoD)**. El Oficial de Seguridad tiene un rol de supervisión, gobernanza, cumplimiento y auditoría interna independiente. Si se le asignara la condición de "Responsable" de aplicar parches, desplegar bases de datos o configurar firewalls, estaría interviniendo operativamente en la infraestructura, perdiendo de inmediato la objetividad, independencia y capacidad crítica para auditar dichas configuraciones más adelante. Su única responsabilidad operativa directa es la vigilancia activa e independiente (**Revisar logs y alertas operativas**), actuando en el resto de los frentes técnicos como un consultor o asesor experto de cumplimiento normativo obligatorio.

P3: En la actividad transversal "Registrar evidencias de mantenimiento" se han asignado cuatro áreas técnicas (Infraestructura, DBA, Desarrollo y Soporte) como "R" en paralelo. ¿Cómo evita esta matriz que los equipos diluyan la culpa o se acusen mutuamente ante omisiones?

R: La responsabilidad técnica de la ejecución no está diluida porque la tarea, aunque consolidada conceptualmente en una sola fila, se aplica de forma individual e independiente sobre el ámbito técnico de competencia de cada actor. Cada área posee la obligación procedimental ineludible de documentar, firmar y almacenar la evidencia e historial de las modificaciones hechas sobre **sus propios sistemas asignados** (el DBA documenta los cambios estructurales en el motor de bases de datos; Infraestructura, el despliegue en los servidores de S.O., etc.). No comparten un único bitácora común confuso, sino que cada departamento responde individualmente por la trazabilidad de su disciplina ante el Jefe de TI, quien resguarda la "A" definitiva.

P4: Al revisar la actividad "Autorizar cambios en producción", el área de Desarrollo aparece listada con el rol de "R" (Responsable). ¿Por qué interviene Desarrollo en el entorno de producción si la separación estricta de ambientes prohíbe esta práctica en la ingeniería de software?

R: Desarrollo ostenta la condición de "Responsable (R)" en esa fila porque es el área obligada a **preparar, certificar y entregar formalmente el paquete de artefactos de software**, el código empaquetado final y los scripts técnicos para el despliegue, asegurando que pasaron las pruebas previas en el entorno de pruebas (QA). No obstante, la ejecución física de la implantación en el ecosistema productivo real es delegada al área de Infraestructura (quien comparte la "R" con un alcance meramente de despliegue de infraestructura), y el Jefe de TI actúa como el único filtro de control técnico y estratégico superior con la "A" (Aprobador final) para habilitar de manera formal el paso a producción. Se preserva así la integridad y separación absoluta de ambientes.

P5: ¿De qué manera práctica asiste la configuración de esta matriz RACI para resolver y mitigar una crisis informática imprevista si el Jefe de TI (Aprobador Último) se encuentra fuera del alcance o incomunicado?

R: La matriz RACI actúa como el mapa de contingencia operativa inmediata de la organización. Aunque el Jefe de TI retiene de manera nominal la condición de Aprobador (A) de los planes, la matriz deja documentado de antemano quiénes son los operadores reales (Responsables - R) con la facultad y el dominio de ejecución sobre cada capa de la infraestructura tecnológica: el equipo de Infraestructura sabe que debe liderar la remediación física o aplicación de parches, el DBA sabe que posee el control técnico exclusivo para orquestar la restauración inmediata desde el Sistema de Respaldos críticos, y el Oficial de Seguridad asume la supervisión forense mediante los logs de eventos. Los equipos técnicos conocen con precisión quirúrgica su ámbito de acción y sus límites operativos, ejecutando los protocolos de recuperación de desastres sin necesidad de esperar por una asignación o delegación manual de funciones en medio de una crisis.